

MODULE 14

Incident Response Fundamentals

Phase 3: Security Operations Fundamentals

SOC Analyst / Tier 1 Focus Cybersecurity Training Program

Module Overview

This module is about what a SOC analyst or incident responder does after suspicious activity has been detected. Students learn the incident response process, how to distinguish an event, alert, and confirmed incident, how to contain common incidents, how eradication and recovery work, and how to document and review an incident.

1. Learning Objectives

By the end of this module, you should be able to:

- Explain what incident response is and why organizations use a structured process.
- Describe the six phases of the incident response lifecycle: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned.
- Explain the difference between an event, an alert, and a confirmed incident.
- Apply basic containment actions to malware infections, compromised accounts, and phishing incidents.
- Explain short-term and long-term containment.
- Explain the purpose of eradication and recovery and why recovery should be performed carefully.
- Identify the main sections of an incident report.
- Explain why Lessons Learned is important after an incident.

2. Why This Module Matters

Earlier SOC topics focus on detecting suspicious activity through logs and alerts. Incident response focuses on what happens next. Once an alert has been investigated and a real security problem is identified, the organization needs a structured way to control the incident, remove the cause, restore normal operations, document what happened, and improve future defenses.

Career Connection: Tier 1 SOC analysts may be among the first people to handle security alerts. They gather evidence, perform basic triage, follow approved playbooks, document actions, and escalate incidents that require deeper investigation.

3. What Is Incident Response?

Simple definition: Incident response = the organized process used to prepare for, identify, contain, eradicate, recover from, and learn from a cybersecurity incident.

Why do we need a structured process?

- Attackers may still be active while the investigation is happening.
- Random actions can destroy evidence.
- Responding too early or too late can increase damage.
- A structured process helps different responders work consistently.
- Documentation allows another analyst or manager to understand what happened.

Understand it with an example

An employee opens a suspicious attachment and the endpoint security tool detects ransomware-related activity. Instead of immediately formatting the computer, the responder first investigates and contains it, preserves useful evidence, removes the threat, restores the system safely, and documents the incident.

4. Event, Alert & Incident

Term	Beginner Meaning	Example
Event	Something observable happened in a system.	A user logs in.
Alert	A security rule or tool flags an event as potentially suspicious.	SIEM detects an unusual login.
Incident	An alert that has been investigated and confirmed as a real security violation or active threat.	Investigation confirms an attacker is using the account.

Easy way to remember: Event = something happened → Alert = check this → Incident = investigation confirms a real security problem.

Important: Not every event is suspicious, and not every alert becomes an incident.

5. Incident Response Lifecycle

Incident response is a repeating process with six phases:

Phase	What Happens	Simple Example
1. Preparation	Build the capability to respond before an incident.	Plans, trained staff, tools, contacts, playbooks.
2. Identification	Determine whether the activity is an incident and understand its scope.	Find affected users, systems, and data.

3. Containment	Limit the spread and impact.	Isolate an infected computer.
4. Eradication	Remove the root cause.	Remove malware or close the exploited weakness.
5. Recovery	Safely restore normal operation and monitor.	Restore a clean system and watch for further suspicious activity.
6. Lessons Learned	Review what happened and improve the process.	Update controls, training, or response procedures.

Memory aid: Prepare → Identify → Contain → Eradicate → Recover → Learn

Phase 1 — Preparation

Preparation happens before an incident. The organization gets people, processes, and technology ready.

- Incident response plans
- Trained responders
- Security tools
- Contact lists
- Playbooks for common scenarios

Example: A company has a phishing-response playbook before a phishing campaign occurs.

Phase 2 — Identification

Identification means deciding whether suspicious activity is actually an incident and determining what is affected.

- What happened?
- When did it happen?
- Which user/account is involved?
- Which host or system is involved?
- What data or services may be affected?
- Is the attacker still active?

Phase 3 — Containment

Containment limits the spread and damage of an incident. It is often the first major action after the situation is understood enough to act safely.

Example: Isolate an infected endpoint from the network so the threat cannot easily communicate or spread.

Important: Do not automatically destroy evidence just to make the alert disappear.

Phase 4 — Eradication

Eradication removes the root cause or attacker presence.

- Remove malware.
- Close or fix the exploited vulnerability.
- Disable or reset compromised credentials.
- Remove attacker persistence where identified.

Phase 5 — Recovery

Recovery returns affected systems to normal operation safely.

- Restore or rebuild systems.
- Restore clean data where needed.
- Re-enable services carefully.
- Monitor systems after restoration.
- Confirm the threat is no longer active before closing the incident.

Phase 6 — Lessons Learned

The team reviews what happened, what worked, what failed, and what should change.

- Was a patch missing?
- Did a detection rule fail?
- Were permissions too broad?
- Did the response process work?
- What should be improved before the next incident?

6. Basic Response to Common Incident Types

A. Malware Infection

- Isolate the affected host from the network.
- Preserve the current state for analysis before wiping or rebuilding.
- Use available AV/EDR information or a hash lookup to help identify the malware.
- Do not power off the machine unless instructed, because volatile evidence may be lost.

B. Compromised User Account

- Disable or reset the affected account.
- Force logout of active sessions.
- Review recent account activity.
- Check for unexpected MFA or authentication changes.

C. Phishing Email Click

- Identify all recipients, not only the person who reported the email.
- Check whether the link was clicked.
- Check whether credentials were entered.
- If credentials were entered, investigate the account as potentially compromised.
- Block the malicious sender/domain/URL using approved controls.

7. Short-Term vs. Long-Term Containment

Type	Meaning	Example
------	---------	---------

Short-term containment	Immediate action that quickly limits the incident.	Disconnect an infected host from the network.
Long-term containment	More durable action that allows safe operation while eradication and recovery are planned.	Use a clean rebuilt system on a segmented network while preserving the original for investigation.

Remember: Containment is about controlling the situation. Eradication is about removing the cause.

8. Incident Reporting

Every incident should be documented. A report helps the investigation, handoff, management communication, and Lessons Learned process.

Report Section	What to Write
Summary	What happened, in plain language.
Timeline	Important events in chronological order with timestamps.
Scope	Which systems, accounts, or data were affected.
Actions Taken	What containment, eradication, and recovery actions were performed and by whom.
Root Cause	How the incident occurred in the first place.
Recommendations	What should change to reduce the chance of recurrence.

Who is the report for?

- Technical responders need enough detail to continue or review the investigation.
- Managers need to understand what happened, the impact, the response, and important recommendations.

9. Why Lessons Learned Matters

Organizations can be tempted to move directly to the next task after systems are restored. The problem is that the weakness that allowed the incident may still exist.

Example: If an incident happened because a missing patch was exploited, simply cleaning the infected computer does not fix the underlying patching problem.

- Improve detection rules.
- Fix missing patches or vulnerabilities.
- Reduce unnecessary permissions.
- Improve security awareness or training.

- Update incident response playbooks.

Hands-On Lab — Incident Response Walkthrough

Work as a beginner Tier 1 SOC analyst. For each scenario, identify the situation, choose appropriate immediate actions, and think about what should be documented.

Scenario 1 — Laptop Malware Alert

Situation: A user's laptop triggers an EDR alert for a known ransomware precursor process. The user says the laptop has been slow since opening an email attachment yesterday.

1. What phase are you in when the alert fires?
2. What is your immediate short-term containment action?
3. What evidence should be preserved before cleanup?
4. What would eradication look like?
5. List three items that should appear in the incident report.

Scenario 2 — Suspicious Login from Abroad

Situation: A SIEM alert shows a successful login to a finance employee's account from a country the employee has never traveled to. Two minutes later, a new mail forwarding rule is created.

6. Is this confirmed as an incident or still an alert? What evidence would help confirm it?
7. What is your first containment step?
8. Why is the new mail forwarding rule significant?
9. What long-term containment or recovery step should follow?

Scenario 3 — Mass Phishing Campaign

Situation: Forty employees receive the same phishing email impersonating IT support and asking them to verify their password on a fake login page. Three employees report clicking the link.

10. What is your first action before contacting the three employees who clicked?
11. For the three employees, what do you need to determine before deciding the response?
12. What containment step protects the other 37 employees?
13. What should be discussed during Lessons Learned?

11. How to Write a Simple Incident Timeline

A timeline makes an investigation easier to understand. Record important events in chronological order.

Example:

09:10 — Phishing email received
09:17 — User clicked malicious link
09:20 — Suspicious login detected
09:25 — Account contained
09:40 — Sessions terminated and credentials reset
10:15 — Investigation continued
11:00 — Recovery/monitoring started

12. Beginner Incident Report Example

Use this as a simple model for student lab submissions.

Section	Example
Summary	A user clicked a suspicious email attachment and an endpoint security tool detected ransomware-related activity.
Timeline	Alert generated at 09:20; endpoint isolated at 09:25; investigation started at 09:30.
Scope	One endpoint and one user account were initially identified.
Actions Taken	Endpoint isolated and evidence preserved for analysis.
Root Cause	Initial evidence suggests the incident began with a malicious email attachment.
Recommendations	Improve email filtering, user awareness, and endpoint detection coverage.

13. Knowledge Check

14. List the six phases of the incident response lifecycle in order.
15. Explain the difference between an event, an alert, and an incident.
16. Explain short-term versus long-term containment.
17. Why should containment normally be considered before eradication?
18. List the main sections of an incident report.
19. Why is preserving evidence important during an incident?
20. Explain why Lessons Learned is important.
21. Give one basic response action for a malware infection.
22. Give one basic response action for a compromised account.
23. Give one basic response action for a phishing campaign.

14. Student Reflection

Write at least 150 words answering: What would you do if a SOC alert showed that an employee may have opened a malicious attachment? Explain how you would think through identification, containment, eradication, recovery, documentation, and Lessons Learned.

15. Common Beginner Mistakes to Watch For

- Treating every alert as a confirmed incident.

- Immediately wiping or shutting down a suspicious system without considering evidence-preservation requirements.
- Skipping containment and jumping directly to eradication.
- Focusing on one alert and ignoring related systems, accounts, or users.
- Failing to document timestamps and actions.
- Writing a report that only says what happened but not what was done.
- Assuming recovery means simply turning the system back on.
- Closing an incident without considering how to prevent recurrence.

16. One-Page Incident Response Cheat Sheet

Concept	Remember
Incident Response	Prepare → Identify → Contain → Eradicate → Recover → Learn
Event	Something observable happened.
Alert	A security tool/rule says: check this.
Incident	Investigation confirms a real security problem.
Containment	Limit spread and damage.
Eradication	Remove the root cause/threat.
Recovery	Restore normal operation safely and monitor.
Report	Summary + Timeline + Scope + Actions + Root Cause + Recommendations.
Lessons Learned	Find what should change before the next incident.

Golden habit: Do not think only about fixing the alert. Think about the whole story: what happened, what is affected, what should be protected, what caused it, and what should improve.

17. Further Reading

- NIST SP 800-61 — Computer Security Incident Handling Guide
- SANS Incident Handler's Handbook
- CISA Incident Response Resources

Source basis: This beginner version follows the structure, terminology, scenarios, and response guidance of the provided Module 14 source. [filecite?turn0file0?L30-L45](#)